

WHITE PLAINS HOSPITAL — INFORMATION SECURITY POLICY SUITE: ADDITIONS & CORRECTIONS

ADDITIONS TO POL-001, POL-002, POL-003 | Version 1.1 | April 2026

This document contains required additions and corrections to the White Plains Hospital Information Security Policy Suite (v1.0, April 2026). Incorporate into the main Policy Suite document before next formal review. Sections are labeled by target policy for easy insertion.

CORRECTION — POL-002: Password Policy

Section 3.1 Amendment — Password Expiration and NIST SP 800-63B Alignment

⚠ POLICY RECONCILIATION NOTICE — INSERT AFTER SECTION 3.1 TABLE

3.1a NIST SP 800-63B Reconciliation Note

This Password Policy references NIST Special Publication 800-63B as a guiding framework. It is important to note that NIST SP 800-63B Section 5.1.1 explicitly states:

"Verifiers SHOULD NOT require memorized secrets to be changed arbitrarily (e.g., periodically). However, verifiers SHALL force a change if there is evidence of compromise of the authenticator."

NIST's position (updated in 2017 and maintained since) is that mandatory periodic password rotation — without evidence of compromise — causes users to make predictable, incrementally modified passwords (e.g., Password2026 → Password2027) which reduces actual security.

WPH Organizational Decision: White Plains Hospital has adopted mandatory 90-day password rotation as an organizational risk decision for the following documented reasons:

Reason for Retention	Explanation
MFA not yet fully deployed	Until MFA is enforced on ALL hospital systems, periodic rotation provides an additional layer of defense. Upon full MFA rollout, this requirement will be reviewed.
Legacy system constraints	Some clinical systems cannot enforce MFA or advanced authentication. Password rotation compensates for this gap in the interim.
Regulatory expectation	Some healthcare auditors and cyber insurance underwriters expect password rotation policies. WPH maintains rotation to meet these external expectations while MFA deployment is completed.
Review trigger	This section SHALL be reviewed and rotation policy evaluated for removal once: (1) MFA is deployed on 100% of ePHI systems, AND (2) a password manager is deployed for all staff accounts. Target review: Q1 2027.

This reconciliation note ensures users and auditors understand that WPH is aware of the tension with NIST guidance and has made a documented, justified organizational decision — not an oversight.

ADDITION — ALL POLICIES: Policy Exception and Waiver Process

Applies to: POL-001 (AUP), POL-002 (Password), POL-003 (Data Classification)

INSERT AS NEW SECTION BEFORE 'POLICY REVIEW' IN EACH POLICY DOCUMENT

X. POLICY EXCEPTION AND WAIVER PROCESS

X.1 When Exceptions Apply

Exceptions to any requirement in this policy may be granted when strict compliance would create a material business or clinical impact, AND when compensating controls can be implemented to achieve an equivalent level of risk management. Examples of legitimate exception scenarios include:

Scenario	Example	Likely Compensating Control
Legacy system limitation	Clinical device cannot enforce 12-character passwords due to firmware constraint	Device on isolated network segment; no direct patient data storage; compensating monitoring
Vendor system constraint	Third-party SaaS tool does not support MFA	Access restricted to VPN; session logging; quarterly access review; contract remediation timeline
Operational emergency	Shared login required during mass casualty event for rapid EHR access	Time-limited exception with audit trail; post-event review mandatory
Clinical workflow conflict	Auto-logout timer impacts care delivery in ICU settings	Physical access controls to workstation area; proximity card reader; screen privacy filter

X.2 Exception Request Process

#	Step	Details	Owner
1	Submit Exception Request	Department manager submits written exception request to GRC Analyst using the WPH Policy Exception Request Form. Must include: policy section affected, business justification, proposed compensating controls, and requested duration.	Department Manager
2	GRC Analyst Risk Assessment	GRC Analyst assesses residual risk if exception is granted. Documents finding within 5 business days. Classifies as: Approve, Approve with Conditions, or Deny.	GRC Analyst
3	CISO Approval	All exceptions require CISO written approval. Exceptions with critical risk impact also require Privacy Officer sign-off. Verbal approvals are not valid.	CISO
4	Exception Register	Approved exceptions are logged in the WPH Policy Exception Register maintained by the GRC Analyst. Register reviewed quarterly. Exceptions expire after maximum 12 months and must be renewed.	GRC Analyst
5	Compensating Controls	Approved compensating controls must be implemented within 30 days of exception grant. GRC Analyst verifies implementation.	Department Manager + IT

X.3 Exception Limitations

The following cannot be excepted under any circumstances: sharing credentials with another person, storing unencrypted PHI on personal devices, disabling audit logging on PHI systems, and transmitting patient SSNs via unencrypted email. These represent absolute policy floors.

ADDITION — POL-003: Data Owner Assignments

Insert as Section 5.3 — Data Owner Registry

INSERT AFTER SECTION 5.2 IN POL-003 (DATA CLASSIFICATION POLICY)

5.3 Data Owner Registry — White Plains Hospital

Every data asset at White Plains Hospital must have a designated Data Owner responsible for classification decisions. The following table assigns Data Owners by data category. Updates to this registry require GRC Analyst and CISO approval.

Data Category	Classification	Data Owner	Steward (Day-to-Day)
Patient PHI / ePHI — all clinical records	RESTRICTED	Chief Privacy Officer	Privacy Officer / GRC Analyst
Epic EHR System Data	RESTRICTED	CISO	IT Security Manager
Patient Billing & Insurance Records	RESTRICTED	Chief Financial Officer	Revenue Cycle Manager
Employee HR Records & Payroll	CONFIDENTIAL	HR Director	HRIS Administrator
Vendor Contracts & BAAs	CONFIDENTIAL	General Counsel	GRC Analyst
Security Policies & Risk Registers	CONFIDENTIAL	CISO	GRC Analyst
Audit Reports & Incident Records	CONFIDENTIAL	CISO	GRC Analyst
Financial Statements & Budget Data	CONFIDENTIAL	Chief Financial Officer	Finance Manager
Departmental Procedures & Protocols	INTERNAL	Department Head (respective)	Department Manager
Staff Schedules & Meeting Notes	INTERNAL	Department Head (respective)	Administrative Staff
Non-sensitive Training Materials	INTERNAL	HR Director	Training Coordinator
Hospital Website Content	PUBLIC	VP of Marketing	Marketing Manager
Press Releases & Public Announcements	PUBLIC	VP of Marketing / CEO	Communications Lead
Job Postings	PUBLIC	HR Director	HR Recruiter

Data Owners are responsible for reviewing their data category classification annually. Classification disputes are escalated to the GRC Analyst and resolved by the Privacy Officer with CISO approval. This registry is reviewed semi-annually.

ADDITION — POL-003: Data Labeling and Tagging Standard

Insert as Section 4.5 — Data Labeling Requirements

INSERT AFTER SECTION 4 TABLE IN POL-003 (DATA CLASSIFICATION POLICY)

4.5 How to Label Your Data — Practical Requirements

Classification labels must appear visibly on data in all formats. This section defines exactly how to apply labels in each medium. All staff are responsible for applying labels correctly. If you are unsure, treat the data as CONFIDENTIAL until confirmed.

Format	Where to Label	Exact Requirement
Electronic Documents (Word, Excel, PDF)	Document header AND footer	Insert classification label in document header: e.g., "CLASSIFICATION: RESTRICTED — HIPAA PHI". Footer must show: "CONFIDENTIAL White Plains Hospital [Date] Authorized Recipients Only".
Emails containing PHI	Subject line prefix	Prefix subject line with classification: "[RESTRICTED] Patient Record — John Doe DOB 01/01/1980". Body: use encrypted email channel for all RESTRICTED data. Never send PHI via personal email.
File Names (SharePoint, network drives)	Filename prefix	Use prefix convention: [R] = RESTRICTED, [C] = CONFIDENTIAL, [I] = INTERNAL, [P] = PUBLIC. Example: [R] Patient_Discharge_Summary_2026-04.xlsx
Printed Documents	Header and footer, each page	Each printed page of RESTRICTED or CONFIDENTIAL data must have the classification printed in the header. Add: "PRINTED COPY — DESTROY BY SHREDDING — DO NOT LEAVE UNATTENDED".
Physical Media (USB, CD, external drives)	Physical label on media	Affix physical label: white label with black text showing classification level and owner contact. RESTRICTED media requires colored label (red sticker). Log all RESTRICTED media in the WPH Media Register.
Shared Drives / SharePoint	Folder naming and permissions	Create separate folders per classification level. RESTRICTED folders: access by named individuals only, reviewed quarterly. Folder naming: [RESTRICTED] PHI Data, [CONFIDENTIAL] HR Records, etc.
Verbal Communications	Verbal notice before sharing	Before verbally sharing CONFIDENTIAL or RESTRICTED data: "What I am about to share is confidential. Please treat accordingly." Do not discuss PHI in public areas, hallways, or elevators.

4.6 Label Downgrading Prohibition

No employee may reduce the classification level of data (e.g., from RESTRICTED to CONFIDENTIAL) without written approval from the Data Owner (see Section 5.3) and the GRC Analyst. Unauthorized downgrading of PHI classification is a HIPAA violation.

ADDITION — ALL POLICIES: Cross-Document Reference Table

The following table shows how all WPH GRC documents connect to each other. Use this when citing or referencing other documents in the program.

This Document	References	Specific Section
POL-001 AUP	POL-002 Password Policy	Section 3.2: Prohibited Activities — password sharing. POL-002 defines technical requirements.
POL-001 AUP	POL-003 Data Classification	Section 3.3: PHI handling. POL-003 defines classification levels and handling requirements.
POL-001 AUP	WPH-IRP-2026-001 (IRP)	Section 4: Report suspected security incidents. IRP Section 4 defines how to report and escalate.
POL-002 Password	POL-001 AUP	Section 4: Prohibited Practices. AUP reinforces credential sharing prohibition.
POL-003 Data Classification	WPH Cybersecurity Risk Register	RESTRICTED data maps directly to: WPH-R01, R02, R04, R06, R09 as primary protected assets.
WPH-IRP-2026-001	WPH Cybersecurity Risk Register	IRP Scenario A (Ransomware) = WPH-R03. Scenario B (Breach) = WPH-R06. Scenario C (Phishing) = WPH-R01. Scenario D (Insider) = WPH-R04.
WPH-IRP-2026-001	HIPAA Gap Assessment	IRP addresses gaps: §164.308(a)(6)(i) Incident Procedures and §164.308(a)(1)(ii)(A) Risk Analysis.
HIPAA Gap Assessment	WPH Vendor Risk Assessment	BAA gap (§164.314) drives Vendor Risk Assessment program and MedBill Pro assessment.

Maintain this cross-reference table as the GRC program matures. Update after each new document is added to the program.